Market Research

Competitors, market size, positioning and differentiators for a pre-deployment smart contract security tool

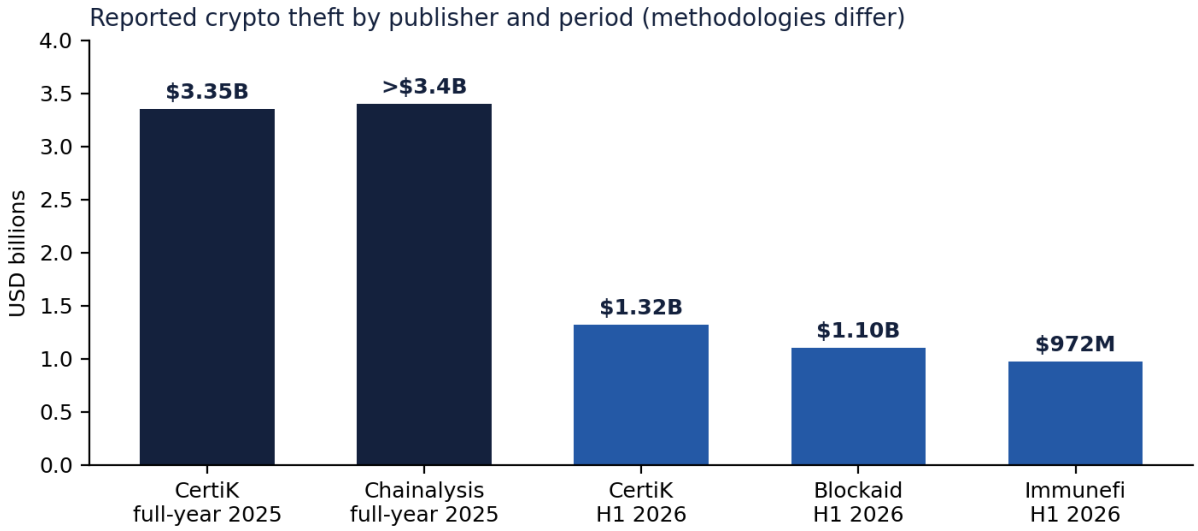
DeFi Contract Auditor (working name) | Draft v0.1 | October 25, 2026
Method: desk research of public sources on October 25, 2026; no customer interviews yet
Read Section 11 (limitations) before relying on any number

1. Executive Summary

- **Demand is real and the stakes are high.** CertiK counted about $3.35B lost across 630 incidents in 2025 and Chainalysis estimated over $3.4B stolen. H1 2026 losses were roughly $1.0B to $1.3B depending on the tracker, and September 2026 was the worst month of the year at about $767M.
- **The paid market is modest but growing.** Published estimates of the smart contract audit market in 2024/2025 range from about $0.8B to $1.8B, with forecasts of roughly $5.5B to $9.6B by 2033/2034 (growth rates of about 17% to 23% a year). These are syndicated-report figures of uneven quality and should be treated as directional.
- **Formal audits are priced for well-funded teams.** Most DeFi protocol audits cost $25,000 to $100,000, which leaves early-stage teams under-served for pre-launch checks.
- **The category is getting crowded fast.** Sherlock launched an AI-plus-researcher 'Audit Engine' in 2026 with self-serve access; venture-backed AI auditors (Olympix, Octane, Almanax and others) sell CI-integrated scanning; open-source tools remain free; and frontier general-purpose models now detect and exploit a large share of known vulnerabilities in benchmarks.
- **Implication.** 'An AI that reads your code' is not a defensible position. The opportunity is a narrow, trustworthy wedge: a deterministic privilege and centralization-risk view, evidence-grounded and verified output, strong privacy, and a founder-friendly pre-flight workflow that complements, not replaces, formal audits.

Headline risks
Biggest strategic risks: (1) frontier models and incumbents commoditize generic AI review; (2) many of the largest losses come from key and infrastructure compromise, which limits what any source-code tool can prevent; (3) trust and credentials, which a new entrant lacks.

2. Why Demand Exists: The Cost of Failure



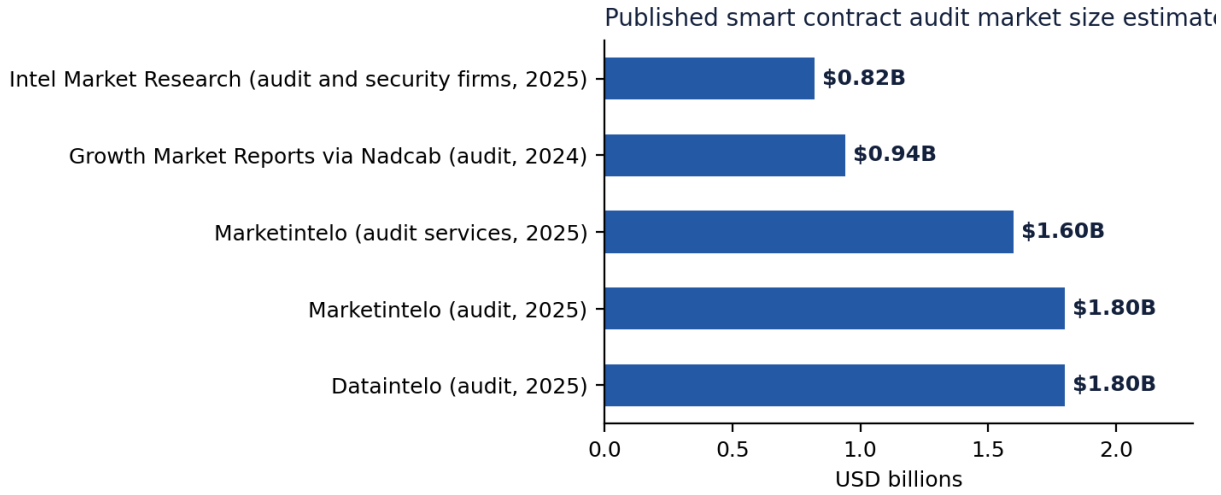
Figures come from different publishers with different definitions (hacks versus all incidents, inclusion of scams, timing). They are directionally consistent, not interchangeable.

Data point	Source and detail
2025 theft	CertiK: $3.35B across 630 incidents (a 37% rise on its restated 2024 baseline). Chainalysis: more than $3.4B stolen in 2025; the Bybit incident alone was roughly 44% of that.
H1 2026	CertiK: about $1.32B across 344 incidents (down 46.8% year over year, but about 28% higher if one historic outlier is removed). Immunefi: about $972M across 207 incidents, a record count for a half-year. Blockaid: about $1.1B.
Concentration	Immunefi: top five hacks of 2024 to 2025 made up 62% of stolen funds and top ten 73%; average theft $24.5M, about 11 times the median. Attacks are frequent and small, with rare giant ones.
Recent months	September 2026: CertiK about $768M and PeckShield about $767M, the worst month of 2026. February 2026 was a low month at roughly $26M to $38M.
Attacker mix	TRM Labs attributed about $643M (roughly 66%) of H1 2026 theft to North Korea-linked groups; Blockaid put the share at 55%. Large 2026 incidents named in reports include Drift and KelpDAO.
Survival	Immunefi's CEO states nearly 80% of affected projects fail to fully recover.

What a code tool can and cannot influence

Loss categories matter for positioning. In February 2026, CertiK attributed $16.6M to wallet compromise, $11.4M to price manipulation, $8.6M to phishing and only $5.1M to code-vulnerability exploits. A 2026 Sherlock reference cites access-control exploits as the largest category in H1 2025. Source-code tools help most with code flaws and over-powered admin roles; they do little against phishing or stolen keys, except by limiting how much damage one stolen key can do. That last point is exactly what a Privilege Map targets.

3. Market Size



Publisher	Base value	Forecast	Growth
Intel Market Research (audit and security firms)	$0.82B (2025)	$5.47B by 2034	23.2% CAGR
Growth Market Reports, via Nadcab (audit)	$0.94B (2024)	$7.6B by 2033	22.7% CAGR
Dataintelo (audit)	$1.8B (2025)	$7.6B by 2034	17.3% CAGR
Marketintelo (audit)	$1.8B (2025)	$9.6B by 2034	20.4% CAGR
Marketintelo (audit services)	$1.6B (2025)	$15.3B by 2034	not stated here

How to read these numbers

- The spread (roughly 2x) reflects different definitions and methods. Syndicated market reports are often thinly sourced; treat them as order-of-magnitude indicators.
- These figures describe spend on audit *services and firms*, not the pool our product can capture. A self-serve pre-flight tool serves a subset: early-stage teams and reviewers who cannot or will not buy a full audit for every iteration.
- A cross-check from the price side: if most DeFi audits cost $25,000 to $100,000 and security budgets for protocols with meaningful value commonly run $150,000 to $500,000 a year (Sherlock reference), a $1B to $2B market implies on the order of tens of thousands of paid engagements a year. We have not verified this independently.
- **Recommended next step:** a bottom-up estimate (number of new contract deployments by teams under a funding or revenue threshold, times willingness to pay) validated by 15 to 20 interviews. Until then, do not quote a TAM, SAM or SOM externally.

4. Customers and Buying Behavior

Segment	Needs	Buying behavior (evidence and hypotheses)	Fit
Early-stage teams and solo developers	Fast, cheap pre-flight; admin-risk story for investors; fix issues before spending on a full audit.	Formal audit often unaffordable or hard to schedule; scoped by code size and urgency (urgent work carries a 20% to 40% premium). Hypothesis: willing to pay a small fraction of an audit for speed and clarity.	Primary
Independent auditors and contest participants	Faster triage, consistent leads, structured notes.	Use free tools (Slither, Aderyn, Foundry) plus personal workflows; likely to pay only for clear time savings. Hypothesis to test.	Primary
Mid-size protocols with CI pipelines	Continuous scanning on every commit; low noise.	Served today by Olympix, Octane and similar CI-focused tools; strong incumbents.	Later, harder
Institutions and tokenization projects	Credentials, audit trails, compliance mapping.	Sherlock now markets 'institutional security'; EU tokenization is cited as a growth driver. Needs brand and compliance depth.	Later
Compliance managers	Regulatory alignment of token mechanics.	Small and uncertain buyer today; rules in key regions are unsettled (see Section 9).	Deferred

Audits also serve as a **credential** for exchanges, investors and counterparties. A top-tier firm's report carries signaling value independent of review depth, and a software tool cannot supply that. This is why positioning as 'pre-flight and audit-readiness' is safer and more honest than positioning as an audit substitute.

5. Pricing Landscape

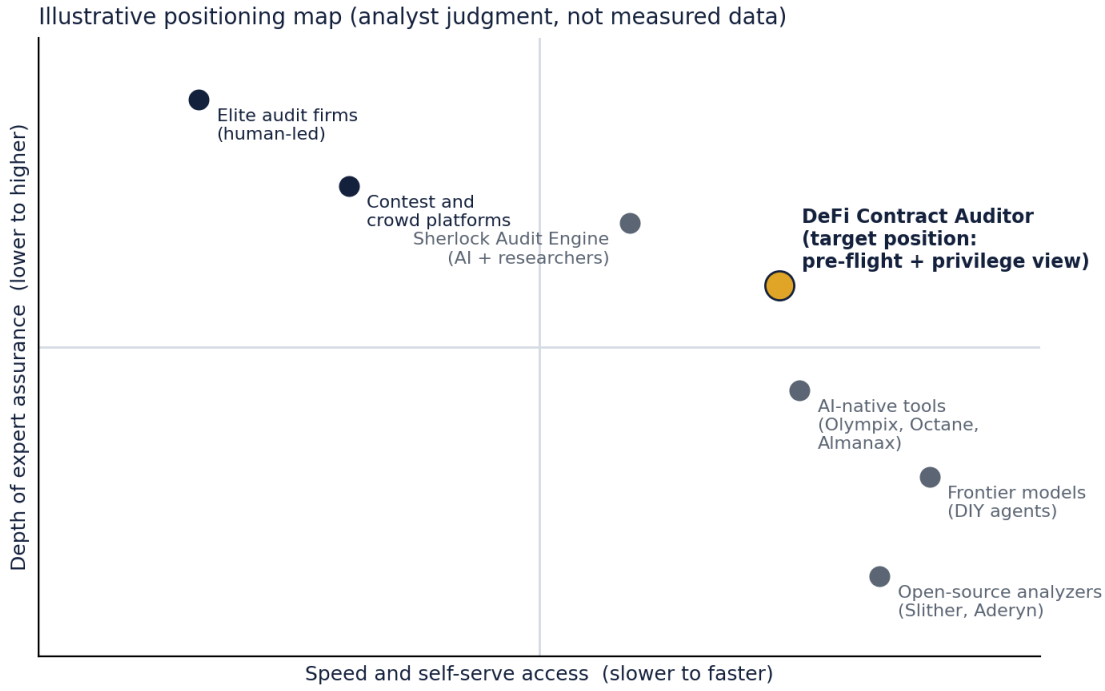
Item	Observed range (Sherlock reference, Feb 2026; a vendor source)
Overall audit price	$5,000 to $250,000+; most DeFi protocol audits $25,000 to $100,000
Simple token	About $5,000 to $20,000
Mid-complexity DeFi protocol	About $40,000 to $100,000; realistic pre-launch budget including one remediation review $60,000 to $120,000
Enterprise / multi-chain	Often above $150,000
Remediation re-audit	About $5,000 to $20,000 per pass
Premiums	Solana/Rust 25% to 40% over Solidity; Move and Cairo 30% to 45%; zero-knowledge circuits 80% to 120%; urgency 20% to 40%
Duration (scope driven)	About 500 non-comment lines: ~3 days in a contest; ~3,000 lines: ~18 days; ~6,000 lines: ~38 days; plus scheduling and remediation
Annual program budgets	Protocols with meaningful value at risk: roughly $150,000 to $500,000 for audits, contests and bounties combined

Our pricing is undecided. No competitor subscription prices were verified in this research. Working hypothesis to test: a free tier that shows the Privilege Map for a small contract (acquisition and trust), paid team plans or per-audit credits priced an order of magnitude below a formal audit, and an auditor plan billed on time saved. Treat all numbers as to-be-validated.

6. Competitive Landscape

Five groups compete for the same security budget or attention. Descriptions reflect public information found on October 25, 2026, much of it from vendor or listicle sources of mixed independence.

Group	Examples (from sources reviewed)	Strengths	Gaps or weaknesses	Threat
Human-led audit firms	Trail of Bits, OpenZeppelin, Spearbit, ConsenSys Diligence, CertiK, Cyfrin, Hashlock, QuillAudits, OtterSec	Credibility, depth, formal verification at some firms, investor and exchange recognition	Cost, scheduling, time; not built for fast iteration	Low (different job) but competes for budget
Contest and bounty platforms	Sherlock contests, Code4rena, Cyfrin CodeHawks, Immunefi (over $110M paid, 400+ programs)	Breadth from 100 to 500 parallel researchers; continuous coverage after launch	Expensive, periodic, not self-serve pre-flight	Low to medium
AI-native security tools	Sherlock AI and Audit Engine, Olympix, Almanax, Octane, QuillShield (free beta), Cecuro, The Hound (research)	CI integration, proprietary data (Sherlock's real audit findings), automated patch suggestions, funding	Noise and trust; mostly detection-led positioning; unproven on novel logic bugs	**High**
Open-source analyzers	Slither, Mythril, Aderyn (Cyfrin), Foundry fuzzing	Free, trusted by auditors, scriptable	Technical UX; no explanation, evidence or fixes; noisy	Medium: price anchor at zero, also our foundation
General frontier models and agents	Large models run by developers themselves	Rapidly improving, flexible, cheap to try	Unverified output, variable results, no workflow, privacy concerns	**High**, commoditizes basic review



Key competitor notes

Competitor	What public sources say	What it means for us
Sherlock (AI + Audit Engine)	A lifecycle security company (collaborative audits, contests, bounties, coverage). Sherlock AI launched in beta; in 2026 it introduced Audit Engine, which combines frontier models, purpose-built AI auditors and researchers in one engagement, with an October 2026 update adding self-serve reviews, frontier model access and expanded review controls. It also markets institutional security.	Strongest direct threat: brand, data from real audits, and distribution. Do not compete on 'AI review depth'. Note that its pricing page is also marketing, so treat its figures as vendor-sourced.
Olympix	Founded 2022 (New York). Positioned as a proactive security suite integrated into developer workflows; listed as an ecosystem integration on Avalanche's documentation.	Owns the CI/DevSecOps story. Avoid head-on CI competition early.
Almanax	Markets itself as an 'AI Security Engineer' with a proprietary vulnerability-detection model and an open dataset initiative; cited as targeting complex logic issues.	Competes on logic-bug claims. Our logic-bug story should rest on verified evidence, not claims.
Octane Security	Founded 2022 (Los Angeles); seed-stage with about $6.75M raised; continuous scanning of commits with CI/CD integration and automated patch suggestions.	Closest on 'scan plus patch'. Our patch verification and privilege view must be visibly better.
QuillShield (QuillAudits)	Free beta AI analysis for Solidity logic errors.	Free AI alternatives set a low price anchor.
Cecuro	Reported a benchmark in which its purpose-built agent detected vulnerabilities in 92% of 90 exploited DeFi contracts (self-reported, covering about $96.8M of exploit value).	Marketing benchmarks are rising; we need an honest, hold-out evaluation.
The Hound	Research-grade AI auditing approach by a well-known auditor; described as more research artifact than product.	Signals technique diffusion; ideas will be copied.

One educational source counts 27 or more open-source and 25 or more commercial AI auditing tools as of 2026 and names false-positive noise as the main trust problem. The count is a claim from a training vendor and unverified, but the direction (many entrants) is consistent with other sources.

7. What Frontier AI Capabilities Mean for Us

Evidence	Finding
EVMbench (OpenAI, Paradigm, OtterSec; 2026)	Benchmarks detecting, patching and exploiting vulnerabilities from 40 real audit repositories. The best agent detected 45.6% of vulnerabilities and exploited 72.2% of a curated subset.
Independent re-evaluation (2026)	Found a similar detection ceiling (47.5%) but unstable model rankings across runs, uncontrolled variables, and possible training-data overlap for older repositories. Concludes agents have real but bounded capability.
SCONE-bench (Anthropic and MATS fellows, Dec 2025)	405 previously exploited contracts; ten frontier models produced working exploits for 207 of them (about 51%), worth $550.1M in simulated stolen funds. On contracts exploited after the models' training cutoffs, agents still found exploits worth about $4.6M in simulation.

Reading the evidence
Two things are true at once. Frontier agents are already good enough that any basic 'LLM reads contract' product will be commoditized, and they are inconsistent enough that verification, reproducible evidence and honest coverage statements have real value. The same capabilities also mean attackers can use them, which raises the importance of pre-deployment checks. Our design (deterministic ground truth, verifier, reproduced proofs) is aligned with the second point.

8. Positioning and Differentiators

Positioning statement (draft)

For early-stage teams and independent reviewers who need to know what could go wrong before launch, DeFi Contract Auditor is a pre-flight analysis tool that shows who holds dangerous powers in your contracts, flags issues with verifiable evidence, and proposes fixes that have already been tested. Unlike generic AI reviewers, it shows its evidence and its limits, and it keeps your code private. It prepares you for a formal audit; it does not replace one.

Differentiator	Why it could matter	How defensible
Privilege Map with blast-radius scoring and role-holder declarations	Directly addresses key-compromise and centralization risk, a leading loss driver, and is understandable by non-engineers and investors. In the sources reviewed, competitors' public descriptions led with vulnerability detection, CI integration and patch suggestions; none led with a role-and-power view. This is an observation from limited sources, not proof that no one offers it.	Medium. Mostly deterministic and replicable, so execution quality and fixtures matter.
Evidence-or-nothing findings with a deterministic verifier	Answers the main trust complaint (noise and unsupported claims) with exact-quote citations, reproduced proofs, and an explicit 'no precedent found' state.	Medium. Process and rigor; copyable but hard to do well.
Patches verified by recompiling and re-scanning	Fixes that are tested are more useful than suggestions. Octane advertises patch suggestions, so verification and storage-layout checks must be demonstrably stronger.	Medium
Honest coverage statement	Builds credibility with auditors and counters the false-confidence risk that regulators and investors worry about.	Low as a feature, high as brand if consistent.
Privacy design	Short retention, no training, no shared indexing of customer code, option to self-host later. Pre-release code is highly sensitive.	Medium; costly to do properly, easy to claim.
Founder-first workflow and price	Pre-flight at a price early teams can afford.	Low to medium; price can be matched.

SWOT

Strengths	Weaknesses
Clear wedge (privilege view); deterministic core is explainable; evidence and verification culture; small, buildable scope.	No brand, audit credential, or proprietary audit dataset; small team; reliance on upstream tools; privilege heuristics must be proven accurate.
Opportunities	**Threats**
Under-served early-stage segment; audit-readiness hand-off to human auditors; transparent, hold-out benchmarks as a trust asset; ecosystem grant programs and developer communities; EU and tokenization demand later.	Sherlock and others adding self-serve AI; frontier models commoditizing review; free tools anchoring price at zero; customer reluctance to upload unreleased code; a trusted brand incident (false 'all clear').

9. Regulatory Context (why compliance is deferred)

- **India:** crypto is legal but not legal tender and is classed as a virtual digital asset. The framework in force is largely tax-led (30% tax on gains and 1% TDS). Reporting in 2026 describes discussions among the Finance Ministry, SEBI and the RBI on a fuller framework, with SEBI expected to supervise exchanges and the RBI cross-border flows, and a discussion paper expected later in 2026 that may touch DeFi and staking. The RBI told a parliamentary panel in July 2026 that VDAs should not get legal recognition now.
- **EU:** the MiCA regulation has been fully applicable since December 2024, giving a clearer and more stable text corpus than India today. Whether and how it applies to a given decentralized protocol is a legal question requiring counsel.
- **Implication:** a clause-level compliance engine for India would be built on moving and partly undefined text, and many legal obligations concern entities (licensing, reporting, KYC), not code. Defer it; if revived, start with a stable corpus (for example MiCA), frame outputs as 'contract mechanics that raise questions for counsel', and obtain legal review of the corpus.

10. Go-to-Market Hypotheses and Next Research

Go-to-market hypotheses

- **Lead with the free Privilege Map** on small contracts to earn trust and create shareable output (founders send it to investors and auditors).
- **Reach developers where they work:** Foundry and Hardhat communities, hackathons, ecosystem grant programs and builder programs, and audit-contest researcher communities.
- **Partner with human auditors** through an audit-readiness hand-off pack rather than competing with them.
- **Publish honest evaluation results** including a hold-out set of recent incidents, with false-positive rates, to stand apart from marketing benchmarks.
- **Delay CI-first selling** until the core product is proven, since Olympix and Octane are strong there.

Recommended next research (before committing to pricing)

- 15 to 20 interviews: early-stage founders (what they do before an audit, what they would pay, privacy concerns), independent auditors (workflow, tool budget), and two or three audit firms (hand-off interest).
- Verify competitor pricing and packaging by sign-up and by sales conversations; build a feature-by-feature grid against Sherlock Audit Engine, Olympix, Octane and Almanax.

- Run the Privilege Map prototype on 30 to 50 open-source contracts and have auditors rate accuracy; this is both a product test and a marketing asset.
- Estimate bottom-up demand (new deployments by smaller teams) and test a pricing survey.

11. Method, Limitations and Sources

Limitations
This is desk research from public web sources on October 25, 2026. Several sources are vendors describing themselves or competitors (for example Sherlock's pricing guide and AI-tool listicles), and market-size figures come from syndicated report summaries whose methods we could not inspect. Loss figures differ by publisher and definition. Nothing here has been validated with customers. Company descriptions may be out of date or promotional. Please verify before quoting externally.

Sources consulted

- Immunefi 2026 State of Onchain Security, coverage: https://www.crowdfundinsider.com/2026/03/267905-immunefi-study-finds-largest-hacks-increase-in-value/
- Cointelegraph, September 2026 hack totals: https://cointelegraph.com/news/crypto-hacks-total-766m-in-september-peckshield
- Forklog, CertiK H1 2026 report: https://forklog.com/en/news/certik-says-crypto-hack-losses-hit-1-32b-in-h1-2026
- Forklog, Blockaid and Immunefi H1 2026: https://forklog.com/en/?p=101106
- DeepStrike, Web3 security statistics (CertiK, Chainalysis, TRM, FBI): https://deepstrike.io/blog/web3-security-statistics
- Stingrai, crypto hacking statistics 2026: https://www.stingrai.io/blog/crypto-hacking-statistics-2026
- CertiK February 2026 data via MEXC News: https://www.mexc.com/news/824303
- Sherlock, Smart Contract Audit Pricing 2026 (vendor): https://www.sherlock.xyz/post/smart-contract-audit-pricing-a-market-reference-for-2026
- Intel Market Research: https://www.intelmarketresearch.com/smart-contract-auditsecurity-firm-market-44513
- Marketintelo: https://marketintelo.com/report/smart-contract-audit-market
- Dataintelo: https://dataintelo.com/report/smart-contract-security-audit-services-market
- Nadcab summary of Growth Market Reports: https://www.nadcab.com/blog/smart-contract-audit-market-size-growth-share-global-analysis-report-2025-2033
- TechBullion, Top AI auditing tools: https://techbullion.com/top-8-ai-auditing-tools-for-web3-smart-contracts-in-2026/
- CB Insights profiles: https://www.cbinsights.com/company/octane-security and https://www.cbinsights.com/company/olympix
- Zealynx Academy, AI auditing landscape: https://academy.zealynx.io/ai-agents/security/build-ai-auditor/step-1
- EVMbench: https://arxiv.org/abs/2603.04915 and re-evaluation: https://arxiv.org/pdf/2603.10795
- Anthropic, SCONE-bench research: https://www.anthropic.com/research/smart-contracts
- BlockEden summary of SCONE-bench and Cecuro: https://blockeden.xyz/blog/2026/03/10/ai-agents-exploit-smart-contracts-550m-vulnerability-benchmark/
- India regulation: https://www.kalkine.co.in/article/blockchain-crypto/sebi-set-to-play-central-role-in-indias-emerging-crypto-regulatory-framework-ahead-of-budget and https://www.multibagg.ai/market-pulse/articles/rbi-crypto-risks-panel-july2-cmr3tsdlx000nm10jcj1wmba7
- MiCA and India overview: https://anantamias.com/cryptocurrency-blockchain-regulation-india/